

SIMATS ENGINEERING
ASSESSMENT TOOL III – Penetration testing Task

Course:	Code:	CO: CO3
Duration: 90 min	Total Marks: 50	Reg No / Name : Udhayakumar U 192424332

COURSE OUTCOME COVERED

CO3: *Analyze network services using port scanning, ping sweeps, and enumeration techniques across different operating systems to identify vulnerabilities.(BL4)*

Duration: 90 min

Instructions: Answer all questions. Each question carries 10 marks.

1. An organization has commissioned an external penetration test to determine how much information an unauthorized attacker could gather about its internet-facing infrastructure without directly attacking its systems. Using the **theHarvester** tool against the authorized domain **tesla.com**, conduct a comprehensive reconnaissance exercise to identify publicly available email addresses, subdomains, hostnames, IP addresses, URLs, and other relevant infrastructure information. Organize and analyze the collected information to determine how it contributes to the external attack surface, including the risks associated with exposed employee information, unnecessary subdomains, hostnames, and externally hosted services. Finally, prepare a security assessment explaining the information discovered, the most valuable reconnaissance findings, how multiple pieces of information could be combined by an attacker, the associated risks, recommended controls to reduce information disclosure, and which findings should be validated during subsequent penetration-testing phases.
Required Tool: theHarvester.
2. During a penetration-testing engagement, assess the publicly accessible web application **testphp.vulnweb.com** using the **Nikto** tool to identify potentially exposed files and directories, insecure HTTP methods, server configuration weaknesses, information-disclosure issues, outdated components, dangerous files, and other potential security weaknesses. For every significant finding, collect appropriate evidence and determine whether it represents a confirmed vulnerability, a configuration weakness, or an issue requiring further manual validation. Prepare a final assessment including the commands used, significant findings, supporting evidence, potential security impact, likelihood of exploitation, recommended remediation measures, methods for validating remediation, and a prioritized list of the most important findings, with particular attention to exposed files, server-version information, directory listings, insecure HTTP methods, and outdated components. **Required Tool: Nikto.**
3. A company is conducting an external security assessment to determine whether its DNS infrastructure discloses more information than intended. Using the **Dig** utility against the authorized target domain **zonetransfer.me**, perform a detailed DNS enumeration exercise by identifying and documenting the available A, AAAA, MX, NS, CNAME, TXT, SOA, and other relevant DNS records, determining the authoritative servers, and assessing whether an unauthorized DNS zone transfer can be requested. Analyze the results from an attacker's perspective and explain how DNS records can reveal mail infrastructure, server naming conventions, hostnames, service relationships, and other infrastructure

information. Your assessment should identify the DNS records and authoritative servers, determine whether a zone transfer was possible, explain the additional information exposed by a successful zone transfer and the risks of unrestricted AXFR access, discuss how DNS information can be combined with other reconnaissance techniques, recommend appropriate DNS security controls, and explain how remediation can be verified. **Required Tool: Dig.**

4. As part of an internal penetration-testing engagement, assess the authorized Windows/SMB target **192.168.1.100** using **Enum4linux** to determine what information could be obtained through SMB and NetBIOS enumeration before attempting exploitation. Perform comprehensive enumeration to identify available users, groups, shared resources, domain or workgroup information, operating-system details, password-policy information, NetBIOS information, and other exposed SMB configuration details permitted by the target. Analyze the collected information from an attacker's perspective and determine whether it could facilitate credential attacks, privilege escalation, unauthorized access to shared resources, vulnerability identification, or lateral movement. Prepare a report containing the commands used, identified users and groups, discovered shared resources, relevant system and domain information, evidence of anonymous or null-session enumeration, security implications, relationships between accounts, groups and privileges, risks of unnecessarily accessible SMB shares, recommended controls, and a prioritized remediation plan covering SMB configuration, access control, authentication, patching, and network segmentation. **Required Tool: Enum4linux.**
5. During an external penetration-testing engagement, assess the authorized target **scanme.nmap.org** using **Netcat (nc)** to connect to accessible TCP services and collect service responses and banner information. Analyze the responses to determine what technical information the target voluntarily discloses, including service type, protocol, software name, version information, HTTP response headers, operating-system clues, and other implementation details. For each significant observation, explain what information was disclosed, which service provided it, how it could assist an attacker with fingerprinting, whether version information could be correlated with known vulnerabilities, whether the finding represents a vulnerability or merely information disclosure, what additional validation is required, and what remediation measures could reduce unnecessary exposure. Finally, explain how the organization should monitor and periodically reassess externally exposed services and discuss the security implications of service-banner exposure and how accurate service fingerprinting can make subsequent attacks more targeted. **Required Tool: Netcat (nc).**

Code of Conduct:

*I **Udhayakumar U (192424332)** (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.*

Signature of the student:

RUBRICS FOR CALCULATION:

Criteria	Weightage	Level 4 – Exemplary	Level 3 – Proficient	Level 2 – Developing	Level 1 – Beginning
Understanding of Task	20				
Procedure & Execution	25				
Observation & Result	20				
Viva Voce / Conceptual Response	20				
Time Management & Presentation	15				

Criteria	Understanding of Task	Procedure & Execution	Observation & Result	Viva Voce / Conceptual Response	Time Management & Presentation
Weightage	20 (2)	25 (3)	20 (2)	20 (2)	15 (1)
Q1					
Q2					
Q3					
Q4					
Q5					

Important note on the outputs in this document: theHarvester, Nikto, Dig, Enum4linux and Netcat results below are **realistic, illustrative sample outputs**, not a live capture. This environment's network access is locked to package repositories only, so it cannot reach tesla.com, testphp.vulnweb.com, zonetransfer.me, scanme.nmap.org, or the private lab host 192.168.1.100. testphp.vulnweb.com, zonetransfer.me and scanme.nmap.org are public targets explicitly maintained for security-tool practice, so you can run every command below against them directly from your own lab/Kali VM. tesla.com and 192.168.1.100 should only be scanned with the written authorization your course/instructor provides. Any names, emails, usernames, or hostnames shown below are **fabricated placeholders** for illustration only and are not real data about any person or organization. Replace every sample block with your own captured output/screenshots before submission.

Question 1 — OSINT Reconnaissance on tesla.com (theHarvester)

1.1 Understanding of the Task

theHarvester is a passive/OSINT reconnaissance tool: it queries public sources (search engines, certificate-transparency logs, DNS, PGP key servers, code repositories, etc.) rather than sending traffic to the target itself. The goal is to map what an outsider can learn about tesla.com's internet-facing footprint — emails, subdomains, hostnames, and IPs — purely from information the organization has already exposed publicly, with zero direct interaction with its production systems. This makes it the correct first step of any authorized external penetration test.

1.2 Procedure & Execution

Commands

```
# Aggregate results across all supported free sources
$ theHarvester -d tesla.com -b all -l 300
# Certificate-transparency logs specifically (very high yield for subdomains)
$ theHarvester -d tesla.com -b crtsh
# Save results for reporting
$ theHarvester -d tesla.com -b all -l 300 -f tesla theharvester.html
```

Sample output (illustrative placeholder data)

```
https://www.tesla.com/legal
https://shop.tesla.com/checkout
https://investor.tesla.com/reports
https://dev-portal.tesla.com/api-docs
[*] IPs found: 5
-----
203.0.113.10
203.0.113.11
203.0.113.13
203.0.113.16
203.0.113.17
```

(All names, addresses and IPs above are fabricated placeholders used to illustrate the report format — they are not real tesla.com data.)

1.3 Observation & Result

Category	Observation	Attack-Surface Relevance
Emails	Mix of role-based (press, support) and individual-style addresses	Individual addresses reveal naming convention → predictable usernames for phishing/credential attacks
Subdomains	8 hostnames including a dev-portal and a legacy-app subdomain	Non-production/legacy subdomains are frequently under-patched and forgotten by ops teams
IP addresses	5 distinct IPs across the subdomains	Confirms hosting spread; some may sit outside the primary CDN/WAF, becoming a softer target
URLs	Checkout, investor reports, and an API docs page	API docs page can leak endpoint structure and authentication scheme details

The most valuable single finding is the dev-portal / legacy-app subdomain pair: unlike the main marketing and shop domains (almost certainly behind a CDN/WAF and a mature patch cycle), internal-sounding or legacy subdomains are the pieces most likely to be missed during routine hardening and therefore the highest-value pivot point for further testing.

1.4 Viva Voce / Conceptual Response

Q: Why is theHarvester considered passive reconnaissance?

A: Because it queries third-party public sources (search engines, certificate logs, DNS caches) rather than sending probing traffic directly to the target's systems, so the target organization sees no reconnaissance traffic from the tester.

Q: How could an attacker combine the emails and subdomains found here?

A: The email naming convention (e.g. firstname.lastname@tesla.com) lets an attacker guess valid usernames for any exposed login portal on the discovered subdomains (e.g. the dev-portal), turning two separate low-risk findings into a targeted credential-stuffing or password-spray attack.

Q: Which findings should be validated in later penetration-test phases?

A: The dev-portal and legacy-app subdomains should be prioritized for active scanning (Nmap/Nikto) to confirm whether they are actually reachable, still running old software, and whether any exposed API endpoints require authentication.

Q: What controls reduce the risk from this kind of exposure?

A: Minimize publicly listed individual email addresses in favor of role-based aliases, decommission or firewall unused subdomains, enforce a subdomain inventory/asset-management process, and monitor certificate-transparency logs for unexpected new certificates.

1.5 Summary

tesla.com's public footprint reveals a plausible email-naming pattern and several subdomains, including at least one that looks internal-facing. Overall external information-disclosure risk: **Medium** — nothing here is a vulnerability by itself, but it meaningfully narrows an attacker's target list for the next phase.

Question 2 — Web Application Assessment of testphp.vulnweb.com (Nikto)

2.1 Understanding of the Task

testphp.vulnweb.com is Acunetix's public, intentionally vulnerable PHP test application, maintained specifically for security-tool practice. The task is to run Nikto — an automated web-server scanner — to enumerate exposed files/directories, insecure HTTP methods, outdated components and misconfigurations, then classify every hit as a confirmed vulnerability, a configuration weakness, or something needing manual follow-up.

2.2 Procedure & Execution

Commands

```
# Confirm the web port
$ nmap -p 80,443 testphp.vulnweb.com
# Full Nikto scan
$ nikto -h http://testphp.vulnweb.com
# Include a check of allowed HTTP methods explicitly
$ nikto -h http://testphp.vulnweb.com -Tuning x 6
# Save report
$ nikto -h http://testphp.vulnweb.com -o testphp_nikto.html -Format htm
```

Sample output

```
- Nikto v2.5.0
-----
+ Target IP:          44.228.249.3
+ Target Hostname:    testphp.vulnweb.com
+ Target Port:       80
+ Server: nginx/1.19.0
+ /: Retrieved x-powered-by header: PHP/5.6.40.
+ /: The X-Content-Type-Options header is not set.
+ /admin/: This might be interesting - directory found.
+ /CVS/Entries: CVS Entries file is accessible, revealing source file names.
+ /login.php: Admin login page/section found.
+ /index.bak: A backup file was found.
+ /cgi-bin/test.cgi: This might be dangerous, CGI script exposed.
+ OPTIONS: Allowed HTTP methods: GET, HEAD, POST, OPTIONS, TRACE
+ TRACE method is enabled, allowing Cross-Site Tracing attacks.
+ PHP/5.6.40 appears to be outdated (current stable is 8.x). EOL, unsupported.
+ 7213 requests: 0 error(s) and 10 item(s) reported.
+ End Time: 2026-08-11 (312 seconds)
```

2.3 Observation & Result

Finding	Evidence	Classification	Impact / Likelihood
Outdated PHP 5.6.40 (EOL)	x-powered-by header	Confirmed vulnerability class (unpatched, EOL)	High impact — no further security patches exist; likelihood of a public exploit is high
TRACE method enabled	OPTIONS response	Confirmed configuration weakness	Medium — enables Cross-Site Tracing (XST) in combination with XSS

/CVS/Entries exposed	Direct file retrieval	Confirmed information disclosure	Medium — reveals internal file/source structure
index.bak backup file	Direct file retrieval	Confirmed information disclosure	Medium-High — may contain source/config data
/cgi-bin/test.cgi reachable	Directory/file found	Needs manual validation	Potentially High if the CGI script executes attacker input
/admin/ directory discoverable	Directory found	Needs manual validation	High if unauthenticated access is possible

Prioritized list (highest impact first): (1) outdated/EOL PHP version, (2) exposed backup file, (3) reachable CGI script, (4) TRACE method enabled, (5) /admin/ directory exposure, (6) /CVS/Entries disclosure.

2.4 Viva Voce / Conceptual Response

Q: Why is an outdated PHP version considered high risk even without an active exploit demo?

A: Because an End-of-Life version no longer receives security patches, so any newly disclosed vulnerability in that PHP branch remains permanently unpatched on this host, making it a standing risk rather than a one-time issue.

Q: How would you confirm the TRACE finding is real rather than a false positive?

A: Manually send an HTTP TRACE request with curl or Burp Suite and confirm the server echoes the request back verbatim, which is what enables the Cross-Site Tracing technique.

Q: What's the difference between a 'confirmed vulnerability' and an 'issue needing manual validation' in this report?

A: A confirmed vulnerability was directly evidenced by the scanner's output (e.g., a version banner, a retrievable file), while an issue needing validation was only flagged as reachable/present and requires a manual check to confirm actual exploitability (e.g., testing whether the CGI script executes attacker-supplied input).

Q: How would you validate that remediation worked?

A: Re-run Nikto and manually re-test each specific finding (re-request the backup file, re-send TRACE, re-check the PHP version header) after the fix is deployed, confirming each item now returns 404/403 or a patched version string.

2.5 Summary

Overall risk rating for testphp.vulnweb.com: **High** — an EOL PHP stack combined with an exposed backup file and a reachable CGI script together plausibly chain into remote compromise.

Question 3 — DNS Enumeration of zonetransfer.me (Dig)

3.1 Understanding of the Task

zonetransfer.me is a domain deliberately configured by security researcher Robin Wood to allow unrestricted AXFR zone transfers, for teaching exactly this technique. The task is to enumerate standard DNS record types with dig, identify the authoritative name servers, and attempt a zone transfer to see the full extent of information a misconfigured DNS server can leak in one request.

3.2 Procedure & Execution

Commands

```
# Find the authoritative name servers
$ dig NS zonetransfer.me

# Query individual record types
$ dig A zonetransfer.me
$ dig AAAA zonetransfer.me
$ dig MX zonetransfer.me
$ dig TXT zonetransfer.me
```

```
$ dig SOA zonetransfer.me
$ dig CNAME www.zonetransfer.me
# Attempt an unauthorized zone transfer against an authoritative server
$ dig AXFR zonetransfer.me @nsztm1.digi.ninja
```

Sample output

```
; <<>> DiG 9.18.1 <<>> NS zonetransfer.me
;; ANSWER SECTION:
zonetransfer.me.      7200 IN NS  nsztm1.digi.ninja.
zonetransfer.me.      7200 IN NS  nsztm2.digi.ninja.
; <<>> DiG 9.18.1 <<>> MX zonetransfer.me
;; ANSWER SECTION:
zonetransfer.me.      300  IN MX  0 ASPMX.L.GOOGLE.COM.
; <<>> DiG 9.18.1 <<>> AXFR zonetransfer.me @nsztm1.digi.ninja
;; ANSWER SECTION:
zonetransfer.me.      7200 IN SOA  nsztm1.digi.ninja. ...
zonetransfer.me.      300  IN A    5.196.105.14
www.zonetransfer.me.  7200 IN A    5.196.105.14
mail.zonetransfer.me. 7200 IN A    5.196.105.14
office.zonetransfer.me. 7200 IN A    4.23.39.254
internal.zonetransfer.me. 300 IN A    172.16.0.55
vpn.zonetransfer.me.  4  IN A    174.36.59.154
...
zonetransfer.me.      7200 IN NS  nsztm2.digi.ninja.
;; XFR size: 50 records
```

3.3 Observation & Result

Record Type	Finding	What It Reveals to an Attacker
NS	Two authoritative servers: nsztm1/nsztm2.digi.ninja	Identifies exactly which servers to target for further DNS queries or transfer attempts
MX	Mail routed through Google (ASPMX.L.GOOGLE.COM)	Confirms mail platform for targeted phishing/spoofing research
AXFR (zone transfer)	SUCCESSFUL — ~50 records returned	Full internal naming map disclosed in a single unauthenticated query
Names from AXFR	internal.*, office.*, vpn.* hostnames with real IPs	Reveals internal network naming conventions and non-public infrastructure normally hidden from outsiders

The zone transfer alone converts DNS from a simple name-resolution service into a full infrastructure map: internal-sounding hostnames (internal, office, vpn) and their IPs are exposed in one unauthenticated request, something that would otherwise take extensive manual guessing or brute-forcing to discover.

3.4 Viva Voce / Conceptual Response

Q: What is a DNS zone transfer (AXFR) and why is it dangerous when unrestricted?

A: AXFR is a mechanism for a secondary name server to replicate an entire DNS zone from the primary. It's dangerous when unrestricted because any client — not just authorized secondaries — can request the full record set in one query, exposing every hostname and IP the organization has configured.

Q: How does this combine with other reconnaissance techniques discussed in Q1?

A: Hostnames from the zone transfer (e.g. vpn.zonetransfer.me) can be cross-referenced against theHarvester/OSINT results and then port-scanned individually, letting an attacker build a prioritized target list far faster than blind subdomain brute-forcing.

Q: What is the correct remediation for an open zone transfer?

A: Restrict AXFR to an explicit allow-list of secondary name-server IPs (using the DNS server's transfer ACL, e.g. BIND's allow-transfer directive) and disable transfers to any other requester.

Q: How would you verify the fix?

A: Re-run 'dig AXFR zonetransfer.me @' from an IP outside the allow-list and confirm the server responds with a REFUSED/transfer-failed status instead of returning the zone.

3.5 Summary

DNS security rating: **Critical** for the zone-transfer configuration specifically — an unauthenticated AXFR against zonetransfer.me returns the organization's full internal naming map.

Question 4 — SMB/NetBIOS Enumeration of 192.168.1.100 (Enum4linux)

4.1 Understanding of the Task

Enum4linux automates SMB/NetBIOS enumeration against Windows or Samba hosts: it queries for users, groups, shares, password policy, and OS/domain details, primarily via null (unauthenticated) or guest SMB sessions. The task is to determine how much of this an attacker could obtain before any credentials are used, since that information directly shapes later credential and privilege-escalation attacks.

4.2 Procedure & Execution

Commands

```
# Full enumeration sweep
$ enum4linux -a 192.168.1.100

# Targeted checks
$ enum4linux -U 192.168.1.100 # users
$ enum4linux -S 192.168.1.100 # shares
$ enum4linux -P 192.168.1.100 # password policy
$ enum4linux -G 192.168.1.100 # groups
```

Sample output

```
Starting enum4linux v0.9.1
Target: 192.168.1.100
----- Target Information -----
NetBIOS name: FILESRV01
Workgroup/Domain: CORP
OS: Windows Server 2016 (or Samba equivalent)
----- Users via RID cycling -----
S-1-5-21-...-500 CORP\Administrator (Local User)
S-1-5-21-...-501 CORP\Guest (Local User)
S-1-5-21-...-1001 CORP\svc_backup (Local User)
S-1-5-21-...-1002 CORP\j.doe_sample (Local User)
----- Share Enumeration -----
Sharename      Type      Comment
-----
ADMIN$         Disk      Remote Admin
C$             Disk      Default share
Public         Disk      General file share
Backups        Disk      Backup staging area
[+] Attempting to map shares on 192.168.1.100
//192.168.1.100/Public Mapping: OK, Listing: OK
//192.168.1.100/Backups Mapping: OK, Listing: OK
----- Password Policy -----
Minimum password length: 7
Password complexity: Disabled
Lockout threshold: None
```

4.3 Observation & Result

Category	Finding	Security Implication
Null session	Enumeration succeeded without credentials	Baseline SMB hardening is missing; anonymous access should not be permitted at all
Users	svc_backup service account + a named individual account enumerated	Service accounts are prime brute-force/credential-attack targets; often over-privileged
Shares	Backups share is world-listable and mappable	Potential access to sensitive backup data without authentication
Password policy	No complexity requirement, no lockout threshold	Makes brute-force/password-spray attacks against enumerated accounts far more likely to succeed

The relationships matter more than any single item: the enumerated svc_backup account, the open Backups share, and the absent lockout policy form a direct chain — an attacker can password-spray svc_backup without fear of lockout, then use it to access the Backups share, which may itself contain further credentials or configuration data enabling lateral movement.

4.4 Viva Voce / Conceptual Response

Q: What is a 'null session' in the context of SMB, and why does it matter here?

A: A null session is an SMB connection established with no username/password (or anonymous credentials). It matters because it allowed enum4linux to pull usernames and shares without any authentication, meaning the information is available to literally any network-connected attacker.

Q: Why is RID cycling effective even when a server tries to hide its user list?

A: RID cycling queries SIDs sequentially rather than requesting a user list directly, so it can enumerate accounts even if the server doesn't expose an explicit 'list users' function, as long as SID-to-name lookups (LSA) are permitted.

Q: How does this enumeration facilitate privilege escalation or lateral movement?

A: Knowing real usernames (especially service accounts) lets an attacker focus password attacks precisely, and access to a writable/readable share like Backups can directly expose credentials, configuration files, or other artifacts that grant further access.

Q: What is the prioritized remediation plan?

A: 1) Disable null/anonymous SMB sessions (RestrictAnonymous / smb signing+auth settings). 2) Remove unnecessary shares and restrict Backups to a specific authenticated group. 3) Enforce password complexity and an account-lockout threshold. 4) Segment the SMB host onto a management VLAN. 5) Patch the OS/Samba version and monitor for repeated enumeration attempts.

4.5 Summary

Overall risk rating for 192.168.1.100: **High** — unauthenticated enumeration alone yields usernames, an accessible sensitive share, and a weak password policy, three findings that combine directly into a credible attack path.

Question 5 — Service Banner Grabbing on scanme.nmap.org (Netcat)

5.1 Understanding of the Task

scanme.nmap.org is the Nmap project's own public host, explicitly provided for testing scanning tools. The task is to connect to its open TCP ports with Netcat and read whatever banners the services return, then assess what an attacker could learn purely from that voluntarily-disclosed information — without exploiting anything.

5.2 Procedure & Execution

Commands

```
# Identify open ports first
$ nmap -p- --min-rate 1000 scanme.nmap.org
# Grab banners on discovered ports
$ nc -nv 45.33.32.156 22
$ nc -nv 45.33.32.156 80
# Send a manual HTTP request to see response headers
$ printf 'HEAD / HTTP/1.0\r\n\r\n' | nc -nv 45.33.32.156 80
```

Sample output

```
$ nc -nv 45.33.32.156 22
(UNKNOWN) [45.33.32.156] 22 (ssh) open
SSH-2.0-OpenSSH_6.6.1p1 Ubuntu-2ubuntu2.13
$ printf 'HEAD / HTTP/1.0\r\n\r\n' | nc -nv 45.33.32.156 80
(UNKNOWN) [45.33.32.156] 80 (http) open
HTTP/1.1 200 OK
Server: Apache/2.4.7 (Ubuntu)
Last-Modified: Wed, 12 Nov 2025 07:12:03 GMT
```

5.3 Observation & Result

Port/Service	Disclosed Info	Fingerprinting Value	Vuln vs. Info Disclosure
22/SSH	OpenSSH 6.6.1p1 on Ubuntu	Confirms exact SSH build + OS family/release generation	Information disclosure; becomes a vulnerability only if this specific build has an unpatched CVE — requires CVE-database cross-check
80/HTTP	Apache 2.4.7 on Ubuntu	Confirms web-server family, version, and OS	Information disclosure; version is old enough to warrant a manual CVE check before calling it a vulnerability

Neither banner is itself proof of an exploitable vulnerability — both need to be cross-checked against a CVE database for that exact version string before being escalated from 'information disclosure' to 'confirmed vulnerability'. What they reliably provide is a fingerprint precise enough to let an attacker pick a small, targeted set of exploits to try rather than guessing broadly.

5.4 Viva Voce / Conceptual Response

Q: Why is precise version disclosure more dangerous than just knowing a port is open?

A: An open port alone only tells an attacker a service exists; the exact version string lets them search public CVE databases for known, pre-built exploits for that specific build, dramatically cutting the effort needed to move from reconnaissance to exploitation.

Q: What additional validation is required before treating a banner as a vulnerability?

A: Cross-reference the exact version against a CVE database (e.g. NVD) to confirm a known, applicable vulnerability exists, and ideally confirm the patch level hasn't already been backported by the vendor even though the version number looks old.

Q: How should an organization monitor externally exposed services over time?

A: Run periodic authenticated external scans (Nmap/Nikto) against its own perimeter, track service versions in an asset inventory, and alert on any newly opened port or changed banner compared to the last baseline.

Q: What remediation reduces unnecessary banner exposure?

A: Suppress or generalize version strings where the software allows it (e.g. ServerTokens Prod in Apache), keep all services patched regardless of whether banners are hidden, and place a reverse proxy in front of services to normalize what's shown externally.

5.5 Summary

scanme.nmap.org discloses precise service and OS version information on both tested ports — useful reconnaissance data, but not by itself a confirmed vulnerability without further CVE cross-referencing.

Consolidated Summary

Q	Tool	Target	Key Finding	Overall Risk
1	theHarvester	tesla.com	Email pattern + legacy/dev subdomains discovered via OSINT	Medium
2	Nikto	testphp.vulnweb.com	EOL PHP, exposed backup file, reachable CGI, TRACE enabled	High
3	Dig	zonetransfer.me	Unauthenticated AXFR zone transfer succeeded (~50 records)	Critical
4	Enum4linux	192.168.1.100	Null-session user/share enumeration + weak password policy	High
5	Netcat	scanme.nmap.org	Precise SSH/Apache version banners disclosed	Medium

Reminder: replace the sample terminal blocks above with your own captured output from your lab/authorized targets before submitting, and sign the Code of Conduct declaration.